

Query prepare

Query prepare

Come inviare query sicure al database evitando SQL injection.

Il problema

Quando una query contiene dati inseriti dall'utente, non devi incollarli direttamente nella stringa SQL.

Questo e pericoloso:

```
<?php
$sql = "SELECT * FROM utenti WHERE email = '$email'";
```

Se `$email` contiene testo malevolo, la query puo cambiare significato. Questo rischio si chiama **SQL injection**.

Prepared statement

Una query preparata separa la struttura della query dai valori.

```
<?php
$sql = "SELECT * FROM utenti WHERE email = :email";
$stmt = $pdo->prepare($sql);
$stmt->execute(["email" => $email]);

$utente = $stmt->fetch();
```

`:email` e un placeholder, cioe un segnaposto. Il valore vero arriva dopo, in modo controllato.

SELECT sicura

```
<?php
$email = $_POST["email"] ?? "";

$stmt = $pdo->prepare("SELECT * FROM utenti WHERE email = :email");
$stmt->execute(["email" => $email]);

$utente = $stmt->fetch();

if ($utente) {
    echo "Utente trovato";
}
```

`fetch` legge una riga. Se non ci sono risultati, restituisce `false` .

INSERT sicuro

```
<?php
$stmt = $pdo->prepare(
    "INSERT INTO utenti (nome, email) VALUES (:nome, :email)"
);

$stmt->execute([
    "nome" => $nome,
    "email" => $email,
]);
```

Anche qui i valori non vengono incollati nella query.

Regola pratica

Ogni volta che una query usa dati esterni, usa `prepare` ed `execute` con placeholder. E una delle abitudini più importanti per scrivere PHP sicuro con i database.

Placeholder con punto interrogativo

Oltre ai placeholder con nome, puoi usare `?` .

```
<?php
$stmt = $pdo->prepare("SELECT * FROM utenti WHERE email = ?");
$stmt->execute([$email]);
```

Funziona bene per query piccole. I placeholder con nome sono spesso più leggibili quando i valori sono molti.

Leggere più righe

Per una lista di risultati usa `fetchAll` .

```
<?php
$stmt = $pdo->prepare("SELECT * FROM prodotti WHERE prezzo < :massimo");
$stmt->execute(["massimo" => 20]);

$prodotti = $stmt->fetchAll();

foreach ($prodotti as $prodotto) {
    echo $prodotto["nome"] . "\n";
}
```

La query resta sicura perché il valore `20` viene passato separatamente.

Errore comune: preparare e poi incollare lo stesso

Questo non va bene:

```
<?php
$stmt = $pdo->prepare("SELECT * FROM utenti WHERE email = '$email'");
```

Anche se usi `prepare` , hai comunque incollato `$email` nella stringa. Il valore deve entrare tramite placeholder.